PROTOCOLO DE SEGURIDAD DE LA INFORMACIÓN Y RESPALDO CLOUD

Directrices Técnicas de Seguridad Lógica, Cifrado, Respaldos Transaccionales y Continuidad Operativa OdontoCloud SaaS

1. OBJETIVO Y ALCANCE DEL PROTOCOLO

El presente protocolo establece los lineamientos, medidas técnicas, controles organizativos y procedimientos de respaldo aplicados en la plataforma OdontoCloud Colombia para garantizar la confidencialidad, integridad, autenticidad y disponibilidad de la información clínica y administrativa de las instituciones prestadoras de servicios de salud (IPS) y consultorios odontológicos.

2. ARQUITECTURA TECNOLÓGICA E INFRAESTRUCTURA CLOUD

OdontoCloud opera bajo un modelo de Software as a Service (SaaS) desplegado sobre servidores virtuales privados (VPS) de alto rendimiento con sistema operativo Oracle Linux / Linux empresarial, gestionados mediante contenedores Docker aislados. Los componentes del sistema (frontend web interactivo, backend de microservicios, API REST y base de datos relacional) se ejecutan en redes internas virtuales segmentadas, impidiendo la exposición innecesaria de puertos a internet público.

Toda la interacción de usuarios con la plataforma se canaliza a través de un proxy inverso seguro que aplica cifrado obligatorio en tránsito mediante protocolo HTTPS con certificados SSL/TLS 1.3 de última generación y suites criptográficas robustas.

3. AISLAMIENTO LÓGICO MULTI-INQUILINO (MULTI-TENANT SECURITY)

La segregación de la información entre diferentes clínicas odontológicas se implementa a nivel de motor de base de datos relacional (PostgreSQL) mediante la activación de políticas de seguridad por fila (Row Level Security - RLS).

Cada transacción, consulta o mutación de datos ejecutada por un usuario se valida contra el identificador único institucional (organization_id / tenant_id) derivado de su token de autenticación. Este control criptográfico y relacional garantiza de manera matemática que ningún usuario, odontólogo o administrativo de una clínica pueda tener visibilidad ni acceso a los registros clínicos de otra entidad.

4. POLÍTICA VERIFICABLE DE COPIAS DE SEGURIDAD Y RECUPERACIÓN

Para asegurar la resiliencia operativa y la disponibilidad de los datos ante contingencias técnicas, OdontoCloud aplica una política verificable de respaldos:

- **Respaldo Lógico Automatizado:** Se ejecutan copias de seguridad lógicas periódicas de la base de datos relacional mediante la herramienta de volcado transaccional `pg_dump` en formato binario comprimido (.Fc) o instantáneas a nivel de contenedor.

- **Ubicación y Resguardo:** Los volcados se almacenan en el sistema de almacenamiento del servidor host asignado a OdontoCloud, en volúmenes protegidos con permisos estrictos de acceso de nivel de superusuario.
- **Consistencia Transaccional:** Las copias capturan el estado exacto de las tablas clínicas, evoluciones, odontogramas y facturación sin interrumpir la operación asistencial en curso.
- **Prueba de Restauración:** Se mantienen procedimientos documentados de restauración de datos a través de utilidades estándar (`pg_restore`), permitiendo reanudar la operación del servicio en caso de fallo del contenedor.
- **Deber de Respaldo Local de la IPS:** Sin perjuicio de las copias de seguridad de la infraestructura cloud, la clínica contratante tiene el derecho y la obligación de realizar sus propias descargas periódicas de historias clínicas mediante los módulos de exportación del sistema.

5. CONTROLES DE ACCESO, AUTENTICACIÓN Y CREDENCIALES

El acceso a la plataforma se rige por un esquema de control de acceso basado en roles (Role-Based Access Control - RBAC), diferenciando perfiles:

- **Administrador de Clínica:** Configuración institucional, tarifas, consentimientos y supervisión de usuarios.
- **Odontólogo / Especialista:** Acceso asistencial a agenda, anamnesis, odontograma, evoluciones, adendas y prescripción.
- **Recepción / Admisiones:** Asignación de citas, registro de datos demográficos y facturación, con acceso restringido a la intimidad de la evolución médica.
- **Responsabilidad del Cliente sobre Credenciales:** Las contraseñas de acceso deben ser custodiadas con estricto carácter personal e intransferible por cada usuario. Queda terminantemente prohibido el uso de cuentas compartidas o genéricas. El cliente es responsable de revocar inmediatamente el acceso a funcionarios desvinculados.

6. TRAZABILIDAD, AUDITORÍA Y PROTOCOLO DE CONTINGENCIA ASISTENCIAL

El sistema registra de forma automática en bitácoras protegidas cada intento de acceso, modificación de registros clínicos, emisión de facturas y eventos críticos de seguridad. En situaciones de urgencia vital donde se requiera acceso asistencial extraordinario, la plataforma contempla procedimientos de contingencia que registran indeleblemente la justificación médica de la consulta (protocolo Break-Glass).

7. GESTIÓN DE INCIDENTES DE SEGURIDAD Y NOTIFICACIÓN EN 24 HORAS

Ante la detección de cualquier evento confirmado que comprometa o amenace la confidencialidad de datos personales sensibles de salud, OdontoCloud activará el protocolo de contención técnica y notificará formalmente al Representante Legal de la IPS afectada dentro de las veinticuatro (24) horas siguientes a su confirmación técnica, conforme a los deberes fijados por la Ley 1581 de 2012.

RESPONSABLE DE SEGURIDAD Y ARQUITECTURA TECNOLÓGICA:

JUAN EDUARDO MADRID REQUENA

Titular y Desarrollador — Persona Natural Comerciante
C.C. No. 1102849760 de Sincelejo | NIT: 1102849760-5
OdontoCloud Colombia — Sede Sincelejo, Sucre
Canal Técnico: bienvenido@odontocloudcolombia.com